



**UNIVERSIDAD MARIANO  
GÁLVEZ DE GUATEMALA  
FACULTAD DE INGENIERÍA EN SISTEMAS DE  
INFORMACIÓN**

**PROGRAMA DE POSGRADOS**

**Proyecto Final**

**IMPLEMENTACIÓN DE UN SISTEMA DE GESTIÓN DE  
SEGURIDAD DE LA INFORMACIÓN (SGSI)**

**Autor (es):**

|                                          |                      |
|------------------------------------------|----------------------|
| <b>Villar Vanegas, Maryory Mercedes</b>  | <b>1493-14-14448</b> |
| <b>Lobos Agustín, Hairo Alexander</b>    | <b>1493-13-150</b>   |
| <b>Grijalva Juarez, Bryan Alexsander</b> | <b>1493-15-2363</b>  |
| <b>Lopez Sanchez, Darwin Rubelcy</b>     | <b>1493-13-87</b>    |

**Profesor**

**Ing. Osberto Saul Gallo Orozco**

**Curso**

**Estándares de Seguridad – 04 - 2025**

**Guatemala, 30 de noviembre**

## Contenido

|                                                                        |                                      |
|------------------------------------------------------------------------|--------------------------------------|
| Resumen Ejecutivo .....                                                | 5                                    |
| Introducción .....                                                     | 7                                    |
| Justificación .....                                                    | 8                                    |
| Objetivo General .....                                                 | 9                                    |
| Objetivos Específicos .....                                            | 9                                    |
| Alcance .....                                                          | 10                                   |
| Limites .....                                                          | 10                                   |
| Proyección del Proyecto .....                                          | 11                                   |
| Fases del Proyecto .....                                               | 11                                   |
| Alcance Temporal .....                                                 | 11                                   |
| Actividades Relevantes por Etapa .....                                 | 11                                   |
| Visión General .....                                                   | 13                                   |
| Objetivos Para Cumplir .....                                           | 13                                   |
| Marco Teórico .....                                                    | 14                                   |
| 1. Seguridad de la Información y su Gestión .....                      | 19                                   |
| 2. Norma ISO/IEC 27001 y su Aplicación .....                           | 19                                   |
| 3. Análisis de Riesgos con NIST SP 800-30 .....                        | 20                                   |
| 4. Evaluación del Riesgo con el Modelo OCTAVE .....                    | 20                                   |
| 5. Continuidad del Negocio – Norma ISO 22301 .....                     | 21                                   |
| 6. Arquitectura Zero Trust (ZTA) .....                                 | 21                                   |
| 7. Marco NIST Cybersecurity Framework (CSF) .....                      | 22                                   |
| 8. Gobernanza y Gestión de Servicios de TI: COBIT 2019 e ITIL v4 ..... | 22                                   |
| 9. Estándar TIA-942 para Centros de Datos .....                        | 23                                   |
| 10. Seguridad en Nube Pública (AWS) .....                              | 23                                   |
| 11. Buenas Prácticas de Seguridad en Entornos Bancarios .....          | 24                                   |
| Conclusión del Marco Teórico .....                                     | 25                                   |
| Metodología .....                                                      | 26                                   |
| Marco de Referencia .....                                              | <b>¡Error! Marcador no definido.</b> |
| Antecedentes de la Entidad y Relación con la Tecnología .....          | <b>¡Error! Marcador no definido.</b> |
| Inventario de sistemas de información .....                            | 40                                   |
| Conclusiones .....                                                     | 42                                   |
| Análisis de cumplimiento legal de la entidad .....                     | 44                                   |
| Referencias .....                                                      | 45                                   |
| Anexos .....                                                           | 46                                   |



## Índice de tablas

|                                                                                                     |                                          |
|-----------------------------------------------------------------------------------------------------|------------------------------------------|
| Tabla 1 Fases del proyecto. Elaboración propia .....                                                | 11                                       |
| Tabla 2 Requisitos de Seguridad y Servicios AWS. Elaboración propia.....                            | 15                                       |
| Tabla 3 Normativas y Estándares aplicables. Elaboración propia .....                                | 24                                       |
| Tabla 4 Relación entre Capas de Arquitectura y Estándares de Seguridad.<br>Elaboración propia ..... | 26                                       |
| Tabla 5 Mapeo de capas técnicas con controles normativos. Elaboración propia .                      | 35                                       |
| Tabla 6 Cumplimiento Normativo y su asociación con la arquitectura. Elaboración<br>propia .....     | 37                                       |
| Tabla 7 Inventario de sistemas de información. Elaboración propia                                   | <b>¡Error! Marcador<br/>no definido.</b> |

## Resumen Ejecutivo

El presente proyecto tiene como finalidad diseñar e implementar un Sistema de Gestión de Seguridad de la Información (SGSI) para el Grupo los Cuatro, una organización financiera del sector bancario, como parte de su estrategia de transformación digital y modernización tecnológica. Debido al entorno altamente regulado de la industria bancaria y la naturaleza crítica de los datos que se gestionan, el proyecto se ha estructurado bajo un enfoque integral basado en estándares internacionales de seguridad, continuidad operativa y gobernanza de TI.

El modelo de implementación seleccionado es una arquitectura en nube pública, haciendo uso de Amazon Web Services (AWS) en la región us-east-1. Esta decisión se fundamenta en la necesidad de escalabilidad, resiliencia, cumplimiento normativo y eficiencia operativa. La solución se compone de una infraestructura modular y segmentada por capas, con altos niveles de automatización y monitoreo, adoptando los principios de Zero Trust, aislamiento de red y cumplimiento continuo.

La arquitectura está distribuida en cinco capas fundamentales:

1. **Capa 1** – Seguridad Perimetral: Incluye AWS WAF, autenticación federada con IAM + OIDC, protección contra amenazas a nivel de borde y control de tráfico.
2. **Capa 2** – Red: Segmentación de subredes pública (DMZ), privada (App) y aislada (Data) sobre una VPC (10.0.0.0/16). Cada capa tiene un propósito específico, aplicando NAT Gateways, Security Groups y NACLs.
3. **Capa 3** – Cifrado: Uso de AWS KMS para cifrado de datos en reposo en S3 y DynamoDB, cumpliendo con la política de confidencialidad y protección de datos.

4. **Capa 4** – Observabilidad y Cumplimiento: Implementación de CloudWatch, AWS Config, CloudTrail y Security Hub para auditoría, métricas, cumplimiento continuo y trazabilidad.
5. **Capa 5** – Continuidad del Negocio: Aplicación de respaldos automáticos para S3 y DynamoDB, diseño multi-AZ para alta disponibilidad, y alineación con la norma ISO 22301 y TIA-942 para resiliencia operativa.

El diseño de esta solución responde a la necesidad de:

- Proteger la confidencialidad, integridad y disponibilidad de los datos.
- Cumplir con los marcos normativos como ISO/IEC 27001, NIST SP 800-30, NIST CSF y COBIT 2019.
- Garantizar un análisis de riesgos eficaz, un inventario de activos actualizado y políticas claras de aseguramiento en los accesos y flujos de datos.
- Establecer mecanismos proactivos de detección y respuesta ante incidentes, mediante monitoreo SIEM centralizado y segmentación inteligente.
- Incorporar buenas prácticas de gobernanza de TI bajo ITIL v4, definiendo servicios alineados con los objetivos estratégicos del negocio.

Este proyecto está estructurado por fases, comenzando con el diseño conceptual de la infraestructura, seguido por la construcción del ambiente en AWS, la implementación del SGSI, la adopción de modelos de gobernanza, y finalmente la entrega de documentación formal. Durante todo el ciclo de vida del proyecto, se mantendrá un enfoque basado en riesgos, en cumplimiento y en la mejora continua.

## **Introducción**

En el entorno actual de transformación digital, el sector bancario enfrenta un conjunto de desafíos críticos que exigen una gestión integral de la seguridad de la información. La creciente dependencia cada vez más de servicios digitales, el aumento de las amenazas cibernéticas y las exigencias regulatorias internacionales han motivado a las instituciones financieras a adoptar modelos tecnológicos más seguros, resilientes y alineados con estándares globales. En este contexto, surge la necesidad de implementar sistemas que no solo protejan los activos digitales, sino que también aseguren la continuidad del negocio y la confianza del cliente.

Este proyecto tiene como objetivo la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) para la entidad Grupo los Cuatro, perteneciente al sector bancario, bajo un modelo de arquitectura basado en nube pública de Amazon Web Services (AWS). Esta iniciativa responde a la necesidad de modernizar la infraestructura tecnológica de la organización, aplicando una visión estratégica orientada a la protección de los datos, la gestión de riesgos, el cumplimiento normativo y la gobernanza de TI.

La solución se apoya en principios de segmentación de red, cifrado, continuidad operativa y monitoreo en tiempo real, adoptando marcos normativos reconocidos como ISO/IEC 27001, NIST CSF, COBIT 2019 e ISO 22301. El enfoque está orientado a garantizar la confidencialidad, integridad y disponibilidad de la información, integrando buenas prácticas de gobernanza y resiliencia operativa que respondan a los desafíos actuales del entorno digital bancario.

## **Justificación**

La acelerada transformación digital en el sector bancario ha expuesto a las instituciones financieras a nuevos riesgos relacionados con la seguridad de la información, especialmente en entornos basados en la nube. El manejo de datos confidenciales, como información personal, financiera y transaccional, requiere de controles estrictos que aseguren su protección frente a amenazas internas y externas, así como el cumplimiento con normativas locales e internacionales.

En este contexto, el Grupo los Cuatro, como organización del sector financiero, ha tomado la decisión de adoptar un modelo de operación en la nube pública de AWS, con el objetivo de modernizar su infraestructura tecnológica, mejorar su postura de ciberseguridad y garantizar la continuidad del negocio. Esta transición conlleva la necesidad de implementar un Sistema de Gestión de Seguridad de la Información (SGSI) robusto, basado en estándares reconocidos como ISO/IEC 27001, NIST SP 800-30, ISO 22301, entre otros.

El proyecto es relevante porque aborda de manera práctica la integración de controles de seguridad desde el diseño (security by design), aplicando principios como Zero Trust, segmentación de red, cifrado de datos, monitoreo continuo y políticas de aseguramiento. Esto permitirá a la organización cumplir con los requisitos de seguridad, resiliencia y auditoría, a la vez que se adapta a un entorno tecnológico escalable y flexible.

Además, la implementación de este SGSI representa una oportunidad académica para aplicar conocimientos adquiridos en el programa de Maestría en Seguridad de la Información, reforzando competencias en arquitectura segura, gobernanza de TI y gestión de riesgos. La solución propuesta no solo mejora la seguridad técnica, sino que también impulsa la madurez organizacional en términos de cumplimiento y gestión operativa.



## **Objetivo General**

Diseñar e implementar un Sistema de Gestión de Seguridad de la Información (SGSI) para la organización Grupo los Cuatro, perteneciente al sector bancario, utilizando una arquitectura basada en la nube pública de Amazon Web Services (AWS), que permita proteger los activos de información, gestionar los riesgos de seguridad, garantizar la continuidad del negocio y cumplir con las normativas internacionales aplicables.

### **Objetivos Específicos**

- Diseñar una arquitectura de infraestructura segura en la nube, segmentada en capas, que contemple mecanismos de protección perimetral, cifrado, monitoreo y continuidad operativa, conforme a las buenas prácticas de seguridad en AWS.
- Identificar los activos de información críticos de la organización, realizar un análisis de impacto al negocio (BIA) y aplicar metodologías de evaluación de riesgos (NIST SP 800-30 y OCTAVE).
- Definir e implementar controles de seguridad técnica y administrativa, basados en estándares internacionales como ISO/IEC 27001, ISO 27002 y el marco NIST CSF, que permitan mitigar riesgos y proteger la confidencialidad, integridad y disponibilidad de la información.
- Establecer políticas de aseguramiento para dominios, usuarios, dispositivos y conectividad móvil, que regulen el acceso, uso y protección de los sistemas en la nube.
- Integrar mecanismos de gobernanza y gestión de servicios TI, siguiendo marcos como COBIT 2019 e ITIL v4, para garantizar la operación eficiente, trazabilidad y mejora continua del SGSI.

## **Alcance**

Este proyecto contempla el diseño y simulación de una infraestructura segura sobre AWS, aplicable a una organización bancaria ficticia, e incluye:

- Diagrama de arquitectura segmentada (DMZ, red privada y red aislada)
- Diseño y documentación del SGSI
- Inventario de activos e identificación de riesgos
- BIA, matriz de riesgos y plan de tratamiento priorizado
- Controles de seguridad aplicables a la nube pública
- Políticas de aseguramiento (usuarios, grupos, dispositivos)
- Incorporación de marcos normativos internacionales
- Diseño de gobernanza y administración del entorno implementado

Se trabajará bajo un enfoque teórico-aplicado, en un ambiente académico, con fines educativos.

## **Limites**

- No se contempla la implementación en producción real de servicios bancarios, solo una simulación académica de la infraestructura y sus políticas.
- El entorno será desplegado en forma parcial o virtual, sin conexión a datos reales de clientes o transacciones financieras.
- No se incluirán procesos de auditoría formal o certificación ISO, pero sí se aplicarán los principios y controles establecidos en dichos estándares.
- Las pruebas de resiliencia y seguridad estarán limitadas a escenarios simulados (sin ejecución de pruebas de penetración reales).
- La solución estará acotada al uso de AWS como proveedor de nube pública; no se contemplarán arquitecturas híbridas ni en otras plataformas (Azure, GCP).

## Proyección del Proyecto

La implementación del Sistema de Gestión de Seguridad de la Información (SGSI) para la organización ficticia Grupo los Cuatro ha sido estructuradas en cinco etapas principales, cada una con entregables específicos y fechas bien definidas. El proyecto tiene una duración total estimada de 39 días hábiles, iniciando el 11 de octubre de 2025 y finalizando el 29 de noviembre de 2025, conforme al cronograma oficial del curso

### Fases del Proyecto

| Fase | Nombre                           | Duración | Fechas                  |
|------|----------------------------------|----------|-------------------------|
| I    | Diseño de Infraestructura        | 10 días  | 20/10/2025 – 31/10/2025 |
| II   | Construcción del Ambiente en AWS | 24 días  | 27/10/2025 – 24/11/2025 |
| III  | Elaboración del SGSI             | 21 días  | 27/10/2025 – 20/11/2025 |
| IV   | Gobernanza y Administración      | 5 días   | 20/11/2025 – 25/11/2025 |
| V    | Documentación Final del Proyecto | 5 días   | 25/11/2025 – 29/11/2025 |

*Tabla 1 Fases del proyecto. Elaboración propia*

### Alcance Temporal

Cada fase contiene actividades puntuales, progresivas y conectadas entre sí. Algunas se ejecutan en paralelo (por ejemplo, la construcción del ambiente y el diseño del SGSI), lo que permite optimizar tiempos sin comprometer la calidad de los entregables. El cronograma contempla periodos para pruebas técnicas, documentación formal, revisión académica y presentación final.

### Actividades Relevantes por Etapa

- **Etapa I – Diseño de Infraestructura:**
  - Creación del diagrama de arquitectura
  - Identificación de servidores, dispositivos, firewalls e IDS/IPS
  - Segmentación de red y DMZ

- Diseño de BCP/DRP
- Incorporación de virtualización y políticas Zero Trust
- **Etapla II – Construcción del Ambiente en AWS:**
  - Preparación del entorno en nube pública
  - Configuración de servicios (EC2, S3, IAM, KMS, WAF, etc.)
  - Implementación de monitoreo (CloudWatch, CloudTrail)
  - Validación de conectividad y redundancia
- **Etapla III – Elaboración del SGSI:**
  - Inventario de activos (ISO/IEC 27005)
  - Análisis de riesgos (NIST SP 800-30)
  - Evaluación del riesgo (OCTAVE)
  - Matriz de calor y plan de tratamiento (ISO 22301)
  - Arquitectura Zero Trust y controles de seguridad
- **Etapla IV – Gobernanza y Administración:**
  - Aplicación de ITIL/COBIT para la gestión de servicios TI
  - Administración del entorno implementado según TIA-942
  - Definición de políticas de aseguramiento
- **Etapla V – Documentación Final:**
  - Revisión académica del proyecto
  - Presentación a cátedra
  - Entrega final del documento.

## **Visión General**

La proyección temporal del proyecto permite una ejecución ordenada, con tiempo suficiente para la investigación, el desarrollo técnico y la documentación formal. Además, el enfoque por etapas facilita el cumplimiento progresivo de los objetivos, el control de avances y la entrega de resultados de calidad dentro del tiempo estipulado.

## **Objetivos Para Cumplir**

A lo largo del desarrollo del presente proyecto, se deben alcanzar una serie de objetivos específicos distribuidos por fases, que responden tanto a los requerimientos técnicos como a los criterios de evaluación académica. Estos objetivos permiten estructurar el trabajo, medir avances y garantizar la calidad de la solución propuesta. Los principales objetivos para cumplir son los siguientes:

### **1. Diseño de Infraestructura Segura en la Nube (AWS)**

- Diseñar el diagrama de arquitectura lógico y físico de la solución en nube pública, contemplando segmentación de red (DMZ, subred privada y subred aislada).
- Identificar e integrar componentes críticos de seguridad, como firewalls de nueva generación (WAF), IDS/IPS, mecanismos de autenticación IAM y Zero Trust.
- Incorporar esquemas de continuidad del negocio y recuperación ante desastres (BCP/DRP) conforme a ISO 22301.
- Definir los servicios clave de AWS a utilizar, como S3, EC2, Lambda, API Gateway, DynamoDB, KMS, entre otros.

### **2. Implementación del Ambiente en AWS**

- Preparar y configurar el entorno simulado en AWS, conforme al diseño aprobado.

- Implementar servicios de red, cifrado, monitoreo y seguridad, con énfasis en trazabilidad (CloudTrail), visibilidad (CloudWatch) y cumplimiento continuo (AWS Config).
- Realizar pruebas de conectividad, redundancia y resistencia del entorno.

### **3. Desarrollo del SGSI**

- Elaborar el inventario de activos conforme a ISO/IEC 27005.
- Realizar un análisis de impacto al negocio (BIA) y una evaluación de riesgos aplicando NIST SP 800-30 y el modelo OCTAVE.
- Construir la matriz de riesgo (matriz de calor) y definir un plan de tratamiento priorizado.
- Implementar controles de seguridad técnicos y administrativos basados en ISO 27002 y NIST CSF.
- Establecer políticas de aseguramiento para dominios, grupos, equipos, usuarios, dispositivos móviles y conectividad a la nube.

### **4. Gobernanza de la Información y Administración del Entorno**

- Aplicar modelos de gobernanza TI como ITIL v4 y COBIT 2019 para la gestión de servicios y la mejora continua del entorno implementado.
- Documentar prácticas de administración del entorno según el estándar TIA-942, aplicables al centro de datos y resiliencia operativa en la nube.

### **5. Documentación Formal del Proyecto**

- Redactar el informe final del proyecto con estructura académica completa: introducción, marco teórico, metodología, resultados, discusión, conclusiones y anexos.
- Cumplir con el formato APA, normas de presentación exigidas por la cátedra y estructura de evaluación establecida.

## Resultados Esperados

Como resultado del presente proyecto, se espera la construcción integral de una solución de seguridad de la información basada en estándares internacionales, aplicada a un entorno de nube pública en Amazon Web Services (AWS), orientada a las necesidades específicas del sector bancario. Los resultados esperados se clasifican en cuatro niveles: técnico, documental, estratégico y académico.

Como parte del desarrollo técnico del proyecto, se identificaron los principales requisitos de seguridad establecidos por los estándares seleccionados (ISO 27001, NIST, OWASP, entre otros) y se procedió a mapear cada uno con las herramientas y servicios nativos ofrecidos por AWS. Este ejercicio permite validar que la solución propuesta aprovecha los recursos disponibles en la plataforma para cubrir eficientemente cada control requerido. En la siguiente tabla se detallan los principales servicios de AWS empleados y su correspondencia directa con los requisitos normativos de seguridad:

| Requisito de Seguridad   | Servicio AWS Asociado    | Justificación Técnica                     |
|--------------------------|--------------------------|-------------------------------------------|
| Gestión de identidades   | AWS IAM                  | Permite el principio de mínimo privilegio |
| Auditoría y trazabilidad | AWS CloudTrail           | Registro de eventos e historial           |
| Protección de red        | AWS WAF, Security Groups | Reglas de tráfico definidas por capa      |
| Cifrado de datos         | AWS KMS, S3 Encryption   | Protección de datos en reposo y tránsito  |

*Tabla 2 Requisitos de Seguridad y Servicios AWS. Elaboración propia*

## Resultados Técnicos

- Diseño e implementación de una arquitectura segura en AWS, utilizando segmentación en subredes públicas, privadas y aisladas (DMZ), con integración de servicios nativos como:

- AWS WAF (firewall de aplicaciones).
- IAM + OIDC para control de identidades.
- AWS KMS para cifrado de datos en reposo y en tránsito.
- CloudWatch y CloudTrail para monitoreo, trazabilidad y auditoría.
- Configuración de servicios de alta disponibilidad y continuidad operativa, tales como:
  - Replicación de datos (DynamoDB, S3).
  - Implementación de respaldos automatizados.
  - Redundancia en múltiples zonas de disponibilidad (Multi-AZ).
- Implementación de principios de Zero Trust, autenticación continua, microsegmentación de red y control contextual de accesos.

### **Resultados Documentales y de Control**

- Elaboración de un SGSI formalizado, conforme a la norma ISO/IEC 27001, con todos los componentes clave:
  - Inventario de activos de información y tecnológicos.
  - Análisis de impacto al negocio (BIA) con funciones críticas priorizadas.
  - Análisis y evaluación de riesgos (NIST SP 800-30 y OCTAVE).
  - Matriz de calor y mapa de riesgos clasificados por impacto y probabilidad.
  - Plan de tratamiento de riesgos, con acciones concretas para mitigar vulnerabilidades.
- Documentación de políticas de seguridad, aplicables a:



- Usuarios, grupos y dominios.
- Dispositivos móviles y conectividad remota.
- Cifrado, respaldo y retención de datos.
- Control de accesos físicos y lógicos.

### **Resultados Estratégicos y de Gobernanza**

- Alineación de la infraestructura y procesos con marcos de referencia reconocidos:
  - COBIT 2019 para gobierno de TI.
  - ITIL v4 para operación y gestión de servicios.
  - ISO 22301 para resiliencia operativa y continuidad del negocio.
  - TIA-942 como guía para prácticas de administración del entorno y data center.
- Fortalecimiento de la postura de ciberseguridad institucional, mediante:
  - Reducción de la superficie de ataque.
  - Mayor visibilidad de eventos y riesgos.
  - Respuesta más eficiente ante incidentes de seguridad.
- Cumplimiento con normativas regulatorias aplicables a entidades del sector financiero, como protección de datos personales, prevención de fraudes y trazabilidad de auditoría.

### **Resultados Académicos y de Aprendizaje**

- Aplicación práctica de conocimientos adquiridos en el programa de Maestría en Seguridad de la Información, integrando estándares, marcos y tecnologías reales.

- Desarrollo de capacidades analíticas para la gestión de riesgos, diseño de controles y elaboración de políticas.
- Ejercicio completo del ciclo de vida de un SGSI, desde el diseño técnico hasta la documentación formal y la presentación de resultados.
- Entrega de un documento final bien estructurado, con rigor académico y formato APA, listo para evaluación y presentación ante la cátedra.

Este conjunto de resultados contribuirá a demostrar la viabilidad de adoptar un enfoque estratégico de seguridad en la nube pública, incluso para sectores tan críticos como el bancario. Además, sienta las bases para la mejora continua y futura certificación de la organización en normas como ISO/IEC 27001 o NIST CSF.

## **Marco Teórico**

El presente marco teórico proporciona los fundamentos conceptuales y normativos que sustentan la implementación del Sistema de Gestión de Seguridad de la Información (SGSI), así como los marcos de referencia aplicados para la gestión de riesgos, continuidad del negocio, gobernanza y diseño de infraestructura segura en la nube. Cada uno de estos elementos es esencial para garantizar una solución robusta, conforme y alineada con los objetivos estratégicos de una organización bancaria moderna.

### **Seguridad de la Información y su Gestión**

La Seguridad de la Información se refiere al conjunto de prácticas y controles orientados a proteger la confidencialidad, integridad y disponibilidad de la información. Su adecuada gestión es fundamental para prevenir accesos no autorizados, garantizar la autenticidad de los datos y asegurar la continuidad de las operaciones ante amenazas o eventos disruptivos.

Un Sistema de Gestión de Seguridad de la Información (SGSI) permite implementar una política de seguridad coherente, gestionada y alineada con los objetivos de negocio, evaluando continuamente los riesgos y controlando los activos de información mediante políticas, procedimientos y controles tecnológicos.

### **Norma ISO/IEC 27001 y su Aplicación**

La ISO/IEC 27001 es un estándar internacional para establecer, implementar, mantener y mejorar un SGSI. Define los requisitos necesarios para proteger los activos de información frente a amenazas, garantizando su confidencialidad, integridad y disponibilidad.

Componentes clave de la ISO/IEC 27001:

- Política de seguridad de la información.
- Identificación de activos.

- Análisis y tratamiento de riesgos.
- Controles de seguridad.
- Mejora continua (ciclo PDCA).

La ISO/IEC 27002, por su parte, proporciona las mejores prácticas para la implementación de los controles sugeridos por la ISO/IEC 27001, abarcando seguridad física, lógica, criptografía, gestión de incidentes, control de accesos y continuidad del negocio.

### **Análisis de Riesgos con NIST SP 800-30**

El documento NIST Special Publication 800-30, desarrollado por el Instituto Nacional de Estándares y Tecnología (NIST), presenta una guía para la identificación, evaluación y tratamiento de riesgos asociados a sistemas de información.

Etapas del análisis de riesgos NIST:

1. Identificación de amenazas.
2. Identificación de vulnerabilidades.
3. Determinación de probabilidad de ocurrencia.
4. Análisis del impacto.
5. Evaluación del nivel de riesgo.
6. Definición de medidas de mitigación.

Este enfoque permite priorizar acciones sobre activos críticos, ajustándose a los objetivos del negocio.

### **Evaluación del Riesgo con el Modelo OCTAVE**

El modelo OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation) proporciona una metodología cualitativa para evaluar riesgos en

activos de información, enfocándose en la visión del negocio, el conocimiento organizacional y los criterios operativos.

Fases del modelo OCTAVE:

- Fase 1: Identificación de activos y amenazas.
- Fase 2: Análisis de vulnerabilidades.
- Fase 3: Evaluación de riesgos y planificación de mitigación.

OCTAVE permite a las organizaciones estructurar planes de seguridad adaptados a su realidad operativa.

### **Continuidad del Negocio – Norma ISO 22301**

La ISO 22301 es la norma internacional para la gestión de la continuidad del negocio (BCM). Proporciona un marco estructurado para prepararse, responder y recuperarse de interrupciones significativas.

Componentes principales:

- Análisis de Impacto al Negocio (BIA).
- Identificación de funciones críticas.
- Definición de tiempos de recuperación (RTO/RPO).
- Desarrollo de planes BCP/DRP.
- Pruebas y revisión periódica.

Su aplicación permite a las organizaciones asegurar la resiliencia operativa, minimizar pérdidas y mantener la confianza de los stakeholders.

### **Arquitectura Zero Trust (ZTA)**

El modelo de Arquitectura Zero Trust parte del principio de “nunca confiar, siempre verificar”. En lugar de asumir que todo dentro del perímetro es seguro,

Zero Trust aplica controles estrictos de acceso, autenticación continua y segmentación granular.

Elementos de una ZTA:

- Autenticación multifactor (MFA).
- Identidad como perímetro (IAM/OIDC).
- Microsegmentación de red.
- Control de accesos basados en contexto.
- Monitoreo constante de actividades.

Zero Trust es especialmente relevante en arquitecturas de nube, donde el perímetro de seguridad tradicional se diluye.

### **Marco NIST Cybersecurity Framework (CSF)**

El NIST CSF proporciona una guía flexible para mejorar la postura de ciberseguridad de una organización, basada en cinco funciones esenciales:

1. Identificar (activos, riesgos, entorno).
2. Proteger (controles, accesos, datos).
3. Detectar (anomalías, eventos, monitoreo).
4. Responder (planificación, mitigación, comunicación).
5. Recuperar (resiliencia, restauración).

Este marco se puede adaptar a diferentes niveles de madurez y es ideal para entornos regulados como la banca.

### **Gobernanza y Gestión de Servicios de TI: COBIT 2019 e ITIL v4**

- **COBIT 2019** proporciona un modelo integral para gobernar y administrar la tecnología de la información. Su enfoque se basa en la alineación de TI con

los objetivos estratégicos del negocio, la asignación de responsabilidades y la medición del desempeño.

- **ITIL v4** es un conjunto de prácticas enfocadas en la entrega y gestión eficiente de servicios TI, abordando temas como gestión de incidentes, cambios, disponibilidad y mejora continua.

Ambos marcos son complementarios y fortalecen la sostenibilidad de un SGSI.

### **Estándar TIA-942 para Centros de Datos**

El TIA-942 es un estándar de infraestructura de telecomunicaciones para data centers, que define requisitos de diseño físico, redundancia, disponibilidad y tolerancia a fallos.

Sus componentes clave incluyen:

- Topologías de red y cableado estructurado.
- Clasificación de niveles (Tier I a IV).
- Energía, HVAC, seguridad física y acceso.
- Requisitos de continuidad (en línea con ISO 22301).

Este estándar es útil como referencia para el diseño lógico de entornos en la nube que buscan alta disponibilidad.

### **Seguridad en Nube Pública (AWS)**

Amazon Web Services (AWS) ofrece una amplia gama de servicios que permiten implementar controles de seguridad nativos, incluyendo:

- IAM: control granular de acceso y permisos.
- KMS: gestión de claves y cifrado de datos.
- WAF: firewall de aplicaciones web.
- CloudTrail / CloudWatch: monitoreo, auditoría y trazabilidad.

- Security Hub: evaluación continua de cumplimiento.
- VPC: aislamiento de red, subredes públicas y privadas.

El modelo de responsabilidad compartida de AWS implica que la seguridad "de" la nube es responsabilidad de AWS, mientras que la seguridad "en" la nube recae en el cliente, lo que hace imprescindible una buena planificación de seguridad y configuración de servicios.

La implementación de estándares de seguridad requiere sustentar cada decisión técnica y de gobernanza en normativas reconocidas, tanto en el ámbito internacional como en el sector específico del proyecto (en este caso, bancario y tecnológico). A continuación, se presenta un compendio de las principales normas y estándares utilizados como fundamento teórico y práctico en la propuesta, junto con su aplicación concreta dentro del contexto de la infraestructura en la nube:

| Estándar o Norma | Descripción Breve                                | Aplicación en el Proyecto         |
|------------------|--------------------------------------------------|-----------------------------------|
| ISO/IEC 27001    | Gestión de seguridad de la información           | Base para todo el SGSI            |
| ISO/IEC 27017    | Controles de seguridad para servicios en la nube | Aplicado sobre AWS                |
| NIST SP 800-53   | Controles de seguridad y privacidad              | Refuerzo a controles técnicos     |
| OWASP Top 10     | Riesgos comunes en aplicaciones web              | Considerado en capa de aplicación |

*Tabla 3 Normativas y Estándares aplicables. Elaboración propia*

### **Buenas Prácticas de Seguridad en Entornos Bancarios**

La industria financiera exige niveles elevados de protección debido a su exposición al fraude, al lavado de dinero y al robo de información sensible. Entre las buenas prácticas aplicadas se destacan:

- Cumplimiento regulatorio (PCI DSS, ISO 27001, leyes locales).
- Segmentación de red y control de tráfico.
- Registro de eventos e incidentes (SIEM).



- Pruebas periódicas de vulnerabilidad.
- Gestión de identidades y accesos privilegiados (PAM).
- DLP (Data Loss Prevention) en dispositivos y movilidad.

Estas medidas permiten a las instituciones bancarias fortalecer su postura ante amenazas cada vez más sofisticadas.

### **Conclusión del Marco Teórico**

El marco teórico desarrollado sustenta la relevancia y viabilidad del proyecto de implementación del SGSI para Grupo los Cuatro. Cada estándar, norma y práctica mencionada será aplicada estratégicamente a lo largo de las fases del proyecto, asegurando una solución completa, escalable y alineada con las exigencias del sector financiero y los entornos de nube modernos.

Para garantizar que el diseño arquitectónico propuesto en entornos de nube pública como AWS cumpla con lineamientos reconocidos a nivel internacional, es necesario establecer una correlación explícita entre cada una de sus capas técnicas y los estándares de seguridad aplicables. Esta alineación normativa no solo fortalece el cumplimiento regulatorio, sino que permite implementar controles adecuados en cada nivel de la arquitectura. A continuación, se presenta una tabla que relaciona las capas técnicas del diseño con los marcos normativos y controles específicos que les corresponden:

| Capa de Arquitectura | Descripción                                         | Estándar Aplicable             | Controles Relevantes                       |
|----------------------|-----------------------------------------------------|--------------------------------|--------------------------------------------|
| Capa de Red          | Gestión de VPC, subredes, firewalls                 | ISO/IEC 27033                  | Controles de red, segmentación segura      |
| Capa de Aplicación   | Aplicaciones de negocio desplegadas en EC2 o Lambda | OWASP, NIST SP 800-53          | Validación de entrada, autenticación, logs |
| Capa de Datos        | Bases de datos RDS y almacenamiento S3              | ISO/IEC 27018, NIST            | Encriptación, backup, control de acceso    |
| Capa de Gestión      | IAM, CloudTrail, Config, CloudWatch                 | ISO/IEC 27001, NIST SP 800-171 | Gestión de identidades, monitoreo continuo |

*Tabla 4 Relación entre Capas de Arquitectura y Estándares de Seguridad. Elaboración propia*

## **Metodología**

La metodología aplicada en este proyecto se fundamenta en un enfoque normativo y estratégico, alineado con las mejores prácticas internacionales para la gestión de la seguridad de la información, la arquitectura de sistemas seguros en la nube y la continuidad operativa. A diferencia de un enfoque meramente técnico, esta metodología integra elementos organizacionales, técnicos y académicos con el objetivo de diseñar un Sistema de Gestión de Seguridad de la Información (SGSI) aplicable a un entorno real del sector bancario, utilizando como plataforma la nube pública de Amazon Web Services (AWS).

El proyecto se desarrolla bajo una metodología aplicada de tipo cualitativo, con enfoque documental, técnico y experimental, a través de una simulación académica que replica condiciones reales del entorno operativo de una institución bancaria. Este enfoque permite:

- Integrar marcos normativos y técnicos en un entorno funcional (AWS).
- Analizar y adaptar estándares de seguridad y continuidad del negocio.
- Aplicar herramientas de evaluación de riesgos y controles de mitigación.
- Desarrollar documentación formal y políticas adaptadas a la nube.

A nivel estructural, el desarrollo se guió bajo el ciclo de mejora continua PHVA (Planear – Hacer – Verificar – Actuar), ampliamente utilizado en sistemas de gestión como ISO/IEC 27001. Este modelo metodológico permite un diseño iterativo y enfocado en resultados medibles, que garantizan tanto la conformidad técnica como organizacional.

### **Fundamento Normativo y Estratégico**

La implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) en una organización del sector bancario exige el respaldo de normas internacionales, marcos regulatorios y buenas prácticas que garanticen no

solo la protección de los activos de información, sino también la alineación con los objetivos estratégicos del negocio y el cumplimiento de la normativa vigente.

En este proyecto, el diseño e implementación del SGSI para Grupo los Cuatro, simulado en una arquitectura de nube pública sobre AWS, se sustenta en un conjunto de marcos normativos ampliamente reconocidos, que definen no solo los controles técnicos a implementar, sino también el modelo de gestión, la evaluación de riesgos y la gobernanza de los sistemas de información.

### **ISO/IEC 27001 y 27002 – Gestión de la Seguridad de la Información**

La ISO/IEC 27001 es el estándar internacional que define los requisitos para establecer, implementar, mantener y mejorar un SGSI. Proporciona un marco formal de gestión de riesgos de seguridad y es aplicable a organizaciones de cualquier tamaño y sector, incluyendo la banca, donde su adopción es considerada una mejor práctica regulatoria y reputacional.

El proyecto utiliza esta norma como columna vertebral para estructurar el SGSI, aplicando sus etapas clave:

- Análisis de contexto
- Evaluación de riesgos
- Tratamiento de riesgos
- Aplicación de controles
- Seguimiento y mejora continua (ciclo PHVA)

Por su parte, la ISO/IEC 27002 complementa a la 27001 al ofrecer un catálogo detallado de controles organizacionales, físicos y técnicos. Estos fueron fundamentales para establecer:

- Políticas de control de acceso
- Protección contra software malicioso

- Seguridad en redes y operaciones
- Cifrado de la información
- Seguridad en dispositivos móviles y trabajo remoto

## **ISO/IEC 27005 – Gestión de Riesgos de Seguridad de la Información**

Para realizar el inventario de activos y establecer la relación entre amenazas, vulnerabilidades e impactos, se aplicaron los lineamientos de la ISO/IEC 27005, norma que desarrolla el componente de gestión de riesgos propuesto por la 27001.

Esta norma permitió identificar activos tangibles (infraestructura, dispositivos, bases de datos) e intangibles (reputación, información confidencial), priorizar su importancia y clasificarlos según nivel de exposición y dependencia operativa.

## **ISO 22301 – Continuidad del Negocio**

La continuidad de operaciones en un entorno bancario es crítica. Por ello, se incorporó la ISO 22301 como guía para diseñar las estrategias de BCP (Business Continuity Planning) y DRP (Disaster Recovery Planning) dentro del entorno AWS.

Este estándar se utilizó para:

- Realizar el Análisis de Impacto al Negocio (BIA) que identifica funciones críticas y define los RTO (Recovery Time Objective) y RPO (Recovery Point Objective).
- Diseñar escenarios de interrupción y los mecanismos de recuperación.
- Establecer medidas proactivas como respaldos automáticos, redundancia multi-AZ y recuperación automática de servicios en AWS.

## **NIST SP 800-30 y Modelo OCTAVE – Evaluación de Riesgos**

El proyecto utilizó una doble metodología de análisis de riesgos:

- NIST SP 800-30, desarrollado por el National Institute of Standards and Technology (EE. UU.), para estructurar la identificación de amenazas, vulnerabilidades, niveles de probabilidad e impacto, y para establecer una metodología cuantificable.
- OCTAVE, un modelo cualitativo diseñado por CERT, que permitió complementar la evaluación con una visión organizacional, priorizando riesgos desde el punto de vista del negocio y la cultura de la organización.

Ambos enfoques se usaron para construir la matriz de riesgos y matriz de calor, así como para justificar el **plan de tratamiento** de cada escenario.

## **NIST Cybersecurity Framework (CSF)**

El NIST CSF se utilizó como marco de referencia para establecer un ciclo de defensa estructurado en torno a cinco funciones clave:

1. Identificar (activos, riesgos, procesos)
2. Proteger (medidas técnicas y organizativas)
3. Detectar (eventos, anomalías, SIEM)
4. Responder (planes de acción, notificación, mitigación)
5. Recuperar (resiliencia, restauración, documentación)

Su flexibilidad lo convierte en un complemento ideal para entornos en la nube, permitiendo medir el nivel de madurez en cada dimensión.

## **COBIT 2019 e ITIL v4 – Gobernanza y Gestión de Servicios**

El proyecto integró el marco **COBIT 2019** para garantizar que los procesos de TI estén alineados con los objetivos estratégicos de negocio. Se definieron

políticas de aseguramiento, roles, indicadores y estructuras de control para la gestión del entorno implementado.

En paralelo, se aplicaron prácticas de ITIL v4 para la administración de servicios TI:

- Gestión de cambios y configuraciones
- Gestión de incidentes y problemas
- Mejora continua del servicio

Esto permite no solo controlar técnicamente el entorno, sino también gestionar su operación bajo principios de calidad, trazabilidad y eficiencia.

### **TIA-942 – Buenas Prácticas para Centros de Datos**

Aunque el entorno implementado está basado en nube pública, se tomaron como referencia los lineamientos de la norma TIA-942, que establece los niveles de disponibilidad y tolerancia a fallos en data centers (Tier I a IV).

Esta norma sirvió como guía para:

- Definir la lógica de redundancia y alta disponibilidad
- Establecer condiciones mínimas para continuidad de servicio en la arquitectura simulada
- Aplicar medidas de seguridad física equivalentes en entornos cloud (por ejemplo: zonas aisladas, políticas de acceso y respaldo automatizado)

### **Marco Regulatorio Bancario**

En el sector bancario, además de estándares técnicos, existen requisitos regulatorios de cumplimiento, entre ellos:

- Leyes de protección de datos personales

- Requisitos de confidencialidad de información financiera
- Normativas locales del ente regulador o banco central
- Requisitos de auditoría y conservación de registros

Por ello, la arquitectura implementada consideró medidas como cifrado, trazabilidad, autenticación fuerte y segmentación lógica, para simular un entorno bancario conforme.

### **Técnicas y Estrategias Aplicadas**

La metodología se apoyó en la combinación de varias estrategias complementarias:

- Enfoque por capas de seguridad: Separación lógica del entorno en zonas de seguridad (perimetral, red, cifrado, monitoreo, continuidad).
- Defensa en profundidad: Integración de múltiples controles en diferentes niveles (IAM, WAF, KMS, logging, MFA).
- Modelo Zero Trust: Aplicación del principio de “nunca confiar, siempre verificar” en accesos, identidades y segmentación.
- Simulación de entornos seguros en AWS: Uso de recursos cloud para recrear escenarios reales de infraestructura y pruebas.
- Gestión de activos y riesgos: Priorización de funciones críticas mediante BIA y clasificación de riesgos con matriz de calor.
- Documentación continua: Registro de decisiones, justificaciones técnicas y generación de políticas operativas.

### **Criterios de Validación y Evaluación**

La validación del proyecto no se limita únicamente a la revisión técnica del entorno implementado, sino que contempla un conjunto amplio de criterios divididos en tres niveles: técnico-funcional, normativo-documental y académico-



formal. Esta estructura garantiza que los resultados del proyecto no solo sean viables en un entorno simulado, sino que además cumplan con estándares internacionales, respondan a requerimientos académicos y sean transferibles a escenarios reales, como una auditoría de seguridad o una pre-certificación ISO.

Estos criterios se enfocan en validar que la infraestructura diseñada y desplegada en AWS cumple con los requisitos de seguridad, disponibilidad y trazabilidad esperados. Entre ellos se incluyen:

- Segmentación de red correctamente implementada en la VPC, separando zonas públicas (DMZ), privadas (App) y aisladas (Data).
- Controles de acceso y autenticación basados en políticas IAM, autenticación multifactor (MFA) y principio de privilegios mínimos.
- Trazabilidad y monitoreo activados mediante AWS CloudTrail, CloudWatch y Security Hub.
- Disponibilidad y redundancia, con verificación de configuración Multi-AZ y mecanismos de recuperación.
- Cifrado de datos en reposo (mediante AWS KMS) y en tránsito (usando HTTPS/TLS).
- Pruebas de conectividad, acceso y fallos simulados, para validar la arquitectura lógica y su resiliencia.

Dado que el proyecto está fundamentado en normas internacionales, se establecieron criterios para validar la conformidad del SGSI con los marcos seleccionados, tales como:

- Correspondencia entre los controles aplicados y los del Anexo A de la norma ISO/IEC 27001.
- Inventario de activos elaborado conforme a ISO/IEC 27005, con clasificación por confidencialidad, impacto y criticidad.

- Análisis de riesgos completo, utilizando tanto el enfoque cuantitativo del NIST SP 800-30 como el cualitativo del modelo OCTAVE.
- Existencia de una matriz de riesgos y plan de tratamiento, con priorización de amenazas y definición clara de responsables y medidas.
- Estructura del SGSI alineada al ciclo PHVA, con evidencia de planificación, ejecución, verificación y propuestas de mejora.
- Conformidad con prácticas de continuidad del negocio según ISO 22301, mediante documentación del BIA, RTO/RPO y DRP.

### **Justificación de la Metodología**

La metodología seleccionada fue adecuada por varias razones:

- Permite integrar teoría y práctica, conectando los marcos normativos con su aplicación real en un entorno funcional (AWS).
- Es flexible y modular, lo que facilitó el desarrollo por etapas, sin perder la visión integral del SGSI.
- Está alineada con las exigencias del sector bancario, al enfocarse en cumplimiento, continuidad, protección de datos y trazabilidad.
- Responde a los objetivos académicos del proyecto, permitiendo la documentación formal del proceso y la presentación de resultados con sustento normativo y técnico.

Esta metodología no solo permitió desarrollar un SGSI funcional en un entorno cloud simulado, sino que también sirvió como ejercicio práctico para aplicar marcos internacionales, adaptarlos al contexto bancario y demostrar que es posible construir soluciones de ciberseguridad sólidas, sostenibles y alineadas con los objetivos estratégicos de cualquier organización moderna.

## Relación entre la Arquitectura Técnica y los Controles Normativos

La propuesta de arquitectura técnica no solo responde a necesidades operativas y de seguridad, sino que está cuidadosamente diseñada para alinear cada uno de sus componentes con los controles establecidos en normativas internacionales ampliamente reconocidas, como ISO/IEC 27001:2022 y NIST SP 800-53 Rev. 5. A continuación, se establece la correspondencia directa entre las capas de la arquitectura y los controles normativos que justifican su implementación.

### Mapeo de Capas Técnicas con Controles Normativos

| Capa Arquitectónica             | Servicios AWS Utilizados                        | Control ISO/IEC 27001:2022                 | Control NIST SP 800-53                                  |
|---------------------------------|-------------------------------------------------|--------------------------------------------|---------------------------------------------------------|
| Seguridad de Identidad y Acceso | IAM, WAF, OIDC                                  | A.5.15 - Control de acceso basado en roles | AC-2, AC-3, AC-17 - Control de acceso y autenticación   |
| Seguridad de Red                | VPC, Subredes, NACLs                            | A.13.1 - Protección de redes               | SC-7 - Fronteras de red, tráfico interno/externo        |
| Cifrado de Datos                | AWS KMS, S3 (en reposo), DynamoDB (en tránsito) | A.10.1 - Cifrado de información            | SC-12, SC-28, SC-28(1) - Protección criptográfica       |
| Monitoreo y Auditoría           | CloudTrail, AWS Config, Security Hub            | A.12.4 - Registro de eventos               | AU-2, AU-6 - Registro de auditoría, revisión de eventos |
| Continuidad y Resiliencia       | S3 Backups, Multi-AZ, Alta disponibilidad       | A.17.1 - Continuidad del negocio           | CP-9, CP-10 - Copias de seguridad y restauración        |

*Tabla 5 Mapeo de capas técnicas con controles normativos. Elaboración propia*

## **Análisis por Capa Técnica**

### **Seguridad de Identidad y Acceso**

Se implementan políticas de acceso basado en roles (RBAC) mediante AWS IAM, lo que asegura la separación de privilegios. Se utiliza OIDC para control federado de identidades y AWS WAF para inspección y mitigación de amenazas a nivel de aplicación. Todo esto está alineado con el control A.5.15 de ISO 27001, así como con los controles AC-2 y AC-3 de NIST.

### **Seguridad de Red**

La segmentación de red mediante VPC, Subnets y NACLs permite el aislamiento y control del tráfico. Estas medidas aseguran que solo los servicios autorizados se comuniquen entre sí, cumpliendo con el control A.13.1 de ISO y SC-7 de NIST.

### **Cifrado de Datos**

La arquitectura garantiza que toda la información almacenada en S3 o DynamoDB esté cifrada en reposo y en tránsito mediante AWS KMS, alineado con los requisitos de cifrado de la norma ISO (A.10.1) y los controles NIST SC-12 y SC-28.

### **Monitoreo y Auditoría**

Se activan CloudTrail para trazabilidad de acciones, AWS Config para control de cumplimiento, y Security Hub para correlación de alertas. Esto cumple con los lineamientos de auditoría de ISO (A.12.4) y los controles NIST AU-2 y AU-6.

### **Continuidad del Negocio y Resiliencia**

Se implementan mecanismos de respaldo automático en S3, alta disponibilidad mediante Multi-AZ, y pruebas de recuperación, lo que respalda los requisitos de continuidad (A.17.1) de ISO y los controles CP-9 y CP-10 de NIST.

Esta matriz resume el cumplimiento normativo asociado a la arquitectura:

| Control ISO 27001:2022 | Servicios AWS Implementados         | Estado |
|------------------------|-------------------------------------|--------|
| A.5.15                 | IAM, WAF, OIDC                      | Cumple |
| A.10.1                 | KMS, cifrado en S3/DynamoDB         | Cumple |
| A.12.4                 | CloudTrail, AWS Config, SecurityHub | Cumple |
| A.13.1                 | VPC, Subredes, NACLs                | Cumple |
| A.17.1                 | Backups, Multi-AZ                   | Cumple |

*Tabla 6 Cumplimiento Normativo y su asociación con la arquitectura. Elaboración propia*

## Resultados

### Diagrama de la Solución

A continuación, se presenta el diagrama arquitectónico de la solución propuesta, estructurada en capas de seguridad dentro de un entorno AWS Cloud. Este diseño modular responde a principios estratégicos de defensa en profundidad y adopta marcos normativos como ISO/IEC 27001, NIST 800-53/800-207 (Zero Trust) y CIS Controls v8, para asegurar la protección de los activos digitales.

#### Capa 1: Seguridad Perimetral

Esta capa representa el primer nivel de defensa, donde se implementan controles como IAM con OIDC para la autenticación federada, y AWS WAF para mitigar ataques a nivel de aplicación (ej. SQLi, XSS). Su función es contener amenazas antes de que accedan al sistema interno.

Normas aplicadas:

- ISO/IEC 27001 A.9.2 (Control de acceso de usuarios).
- NIST SP 800-53 AC-7 (Mecanismos contra ataques).

#### Capa 2: Red y Segmentación (VPC)

Dentro de esta capa se define la VPC dividida en tres subredes (DMZ pública, privada y aislada). Se aplican controles de segmentación según el principio de menor privilegio y confianza cero. El acceso entre capas está mediado por controles de red como Security Groups, NACLs, y NAT Gateway.

Normas aplicadas:

- ISO/IEC 27002 13.1.3 (Segmentación de redes).
- NIST CSF PR.AC-5 (Aislamiento de red).
- Zero Trust Architecture (NIST 800-207).

### **Capa 3: Cifrado**

Se utiliza AWS KMS para asegurar el cifrado en tránsito y en reposo de los datos almacenados en S3 y DynamoDB, asegurando la confidencialidad e integridad de la información.

Normas aplicadas:

- ISO/IEC 27001 A.10.1.1 (Política de uso de criptografía).
- NIST SP 800-57 (Gestión de claves criptográficas).

### **Capa 4: Observabilidad**

La observabilidad se garantiza mediante la activación de AWS Config, CloudTrail y CloudWatch, centralizados en Security Hub. Esto asegura visibilidad, cumplimiento, auditoría y reacciones ante eventos sospechosos o incumplimientos.

Normas aplicadas:

- ISO/IEC 27001 A.12.4 (Registros de auditoría).
- NIST SP 800-137 (Continuous Monitoring).

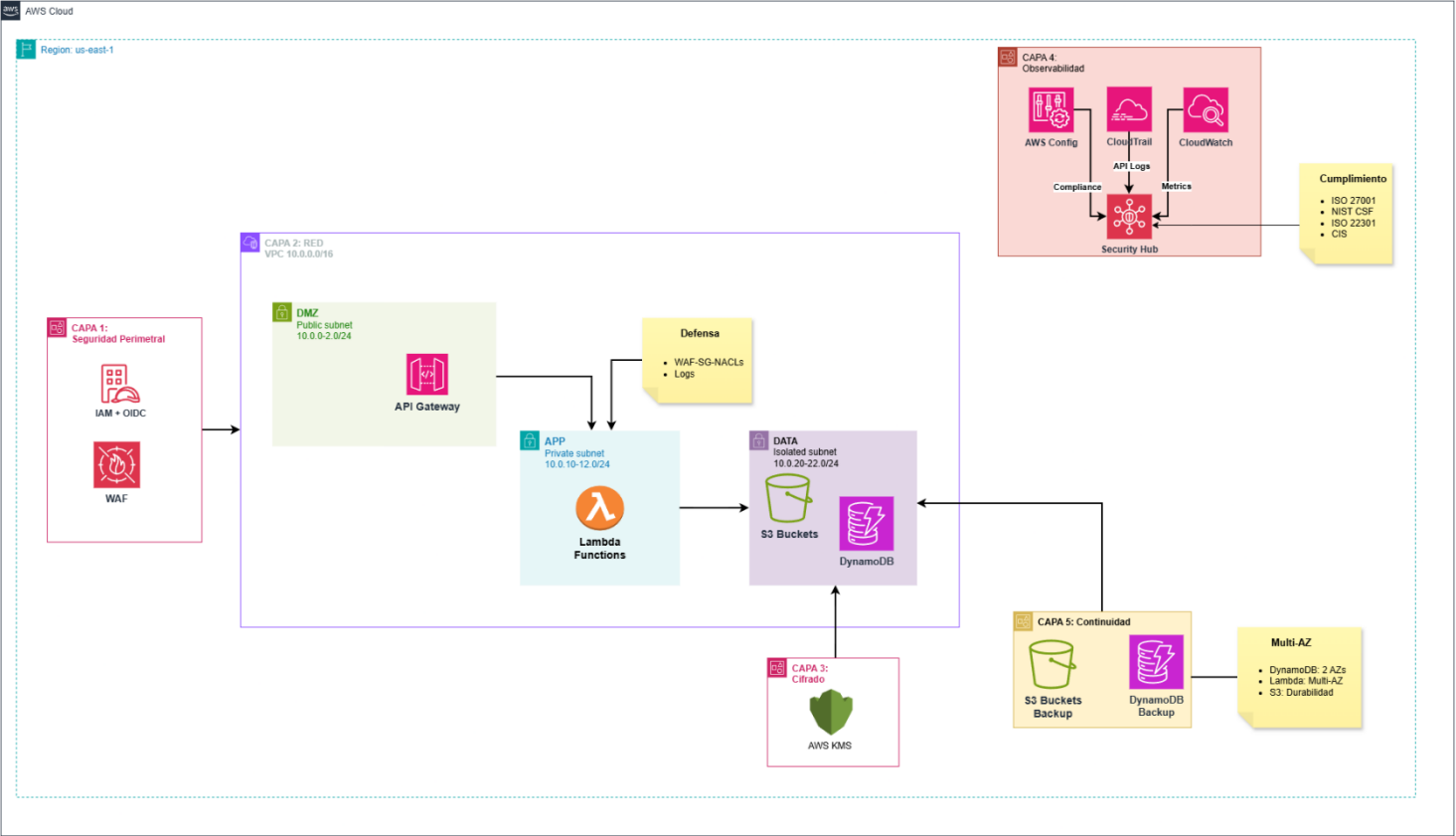
### **Capa 5: Continuidad**

Los mecanismos de respaldo en múltiples zonas de disponibilidad (Multi-AZ) mediante DynamoDB Backup y S3 Buckets Backup aseguran la alta disponibilidad y recuperación ante desastres.

Normas aplicadas:

- ISO/IEC 27001 A.17 (Continuidad del negocio).
- NIST SP 800-34 (Contingency Planning).

Este diseño demuestra cómo cada capa técnica se alinea con controles normativos internacionales y principios de arquitectura segura, fortaleciendo la postura de seguridad de la organización frente a amenazas internas y externas.



Principios de Segmentación:

| Capa     | CIDR            | Acceso Internet    | Propósito             |
|----------|-----------------|--------------------|-----------------------|
| Public   | 10.0.0-2.0/24   | Inbound/Outbound   | DMZ, NAT, API Gateway |
| Private  | 10.0.10-12.0/24 | Outbound via NAT   | Compute (Lambda)      |
| Isolated | 10.0.20-22.0/24 | VPC Endpoints only | Data (DynamoDB, S3)   |

Controles Implementados:

- ISO 27002:8.20 - Segmentación de redes
- NIST CSF PR.AC-5 - Aislamiento de red
- Zero Trust - Sin confianza implícita entre capas

Ilustración 1 Diagrama de Arquitectura en AWS. Elaboración propia



## **Inventario de Activos Críticos (ISO/IEC 27005)**

Uno de los pilares fundamentales para una correcta gestión del riesgo en seguridad de la información es el Inventario de Activos, tal como lo establece la norma ISO/IEC 27005, específicamente en el apartado sobre *identificación y valoración de activos*. Esta actividad permite conocer qué se debe proteger, cuál es su valor para la organización, y qué posibles vulnerabilidades pueden comprometer su confidencialidad, integridad o disponibilidad.

En el contexto de la arquitectura propuesta para la solución en la nube, se ha elaborado un inventario estructurado de activos que considera componentes físicos, lógicos, de información y humanos.

### **Objetivos del Inventario de Activos**

- Identificar los activos que respaldan la operación de los servicios y procesos críticos del negocio.
- Clasificar los activos según su naturaleza (hardware, software, datos, personas, etc.).
- Determinar la criticidad de cada activo para la toma de decisiones de seguridad.
- Asignar responsables (custodios) para su administración y protección.

### **Inventario de Activos**

A continuación se presenta el inventario de activos clasificados por tipo, uso, ubicación y nivel de criticidad, de acuerdo con las buenas prácticas de gestión de riesgos.



## Discusión

## **Conclusiones**

### **Análisis de cumplimiento legal de la entidad**

En el Banco Grupo Los Cinco UMG, la cuestión legal no se ve solo como un

## Referencias

## **Anexos**